AI Governance Maturity Report — Example Regional Bank (synthetic)

Assessment: AI Governance Maturity Self-Assessment (template VERITRAIL-SA-MATURITY v1.0.0)
Generated: 2026-10-21
Evidence status: User-asserted — all answers are self-reported; no evidence has been reviewed.

> *This self-assessment produces an indicative, self-reported view of AI governance maturity. All results are User-asserted: no evidence has been reviewed. Framework readiness indicators are not a determination of conformity with ISO/IEC 42001, compliance with the EU AI Act, or alignment with NIST AI RMF. VERITRAIL does not certify compliance and this report is not legal advice.*

1. Overall maturity

Overall score	Maturity level	Interpretation
48.1 / 100	**Developing**	Basic practices exist but are inconsistent and hard to evidence.

2. Domain scores

Domain	Weight	Score	Profile
Strategy & Accountability	12%	53.3	[##########.....]
AI Inventory & Visibility	14%	40.0	[########.....]
Risk Management & Lifecycle	14%	46.7	[#########.....]
Data & Privacy	12%	53.3	[##########.....]
Security & Resilience	14%	46.7	[#########.....]
Fairness, Safety & Transparency	12%	46.7	[#########.....]
Human Oversight & Operations	12%	53.3	[##########.....]
Assurance, Evidence & Improvement	10%	46.7	[#########.....]

Scoring: domain score = sum of answers ÷ maximum possible × 100; overall = Σ(domain score × weight). Source: VERITRAIL self-assessment template VERITRAIL-SA-MATURITY v1.0.0.

3. Top strengths

- No practices were rated 4 or 5. Strengths will emerge as foundational controls are implemented.

4. Top gaps

#	Domain	Question	Answer	Recommended action	VERITRAIL controls
1	AI Inventory & Visibility	INV-Q1: Does your organization maintain a complete inventory of AI systems, models, agents, and vendor AI products?	2/5	Stand up an AI system of record and run inventory workshops plus shadow-AI discovery to reach full coverage.	EI-01, EI-08, EI-09
2	AI Inventory & Visibility	INV-Q2: Are AI systems classified by business criticality, data sensitivity, decision impact, autonomy, and regulatory relevance?	2/5	Apply VERITRAIL risk-tier criteria to every inventory record and approve tier assignments.	EI-02
3	AI Inventory & Visibility	INV-Q3: Can you identify the owner, purpose, users, data sources, and dependencies for each material AI system?	2/5	Complete owner, purpose, users, data-source and dependency fields for all material AI systems.	EI-03, EI-04, EI-06, EI-10
4	Risk Management & Lifecycle	RSK-Q2: Are model, prompt, data, vendor, and agent changes subject to change control and reassessment?	2/5	Add AI-specific change triggers (model, prompt, data, vendor, tool, agent) to change management with reassessment rules.	GL-04, EI-05

#	Domain	Question	Answer	Recommended action	VERITRAIL controls
5	Risk Management & Lifecycle	RSK-Q3: Is there a defined process for retiring, restricting, or remediating AI systems that no longer meet requirements?	2/5	Define restrict/remediate/retire procedures and an exception register with expiry dates.	GL-09, GL-10

5. Critical risk flags

- **Critical gap — No reliable AI inventory** (trigger: INV-Q1). Without a complete inventory, risk tiering, oversight and evidence cannot be applied to systems you do not know about. Controls: EI-01, EI-09. Evidence status: User-asserted.
- **Critical gap — Sensitive data may reach prompts, logs or external models** (trigger: DAT-Q3). Unredacted personal or confidential data in prompts and logs creates privacy and confidentiality exposure. Controls: IS-04, IS-03. Evidence status: User-asserted.
- **Critical gap — Agents or LLM apps not tested for prompt injection and unsafe tool use** (trigger: SEC-Q2). Agents with tool access that are untested for injection can be manipulated into unauthorised actions or data leakage. Controls: IS-14, IS-11, IS-12. Evidence status: User-asserted.
- **Critical gap — No tested kill switch or rollback** (trigger: SEC-Q3). Without containment, an AI incident cannot be stopped quickly. Controls: IS-15. Evidence status: User-asserted.
- **Critical gap — Cannot produce audit-ready evidence** (trigger: ASR-Q2). Inability to evidence controls undermines responses to auditors, customers and regulators. Controls: SE-05, SE-08. Evidence status: User-asserted.
- **Critical gap — EU-facing AI without consistent AI-interaction disclosure** (trigger: FST-Q2). Transparency obligations for certain AI systems (EU AI Act Art. 50) require readiness; legal review recommended. Controls: IS-08. Evidence status: User-asserted.

6. 30/60/90-day action plan

First 30 days — stabilise

- Stand up an AI system of record and run inventory workshops plus shadow-AI discovery to reach full coverage. (AI Inventory & Visibility; INV-Q1; controls EI-01, EI-08, EI-09)
- Apply VERITRAIL risk-tier criteria to every inventory record and approve tier assignments. (AI Inventory & Visibility; INV-Q2; controls EI-02)
- Complete owner, purpose, users, data-source and dependency fields for all material AI systems. (AI Inventory & Visibility; INV-Q3; controls EI-03, EI-04, EI-06, EI-10)
- Add AI-specific change triggers (model, prompt, data, vendor, tool, agent) to change management with reassessment rules. (Risk Management & Lifecycle; RSK-Q2; controls GL-04, EI-05)
- Define restrict/remediate/retire procedures and an exception register with expiry dates. (Risk Management & Lifecycle; RSK-Q3; controls GL-09, GL-10)

Days 31–60 — standardise

- Make a tier-proportionate risk and impact assessment a mandatory gate before any production deployment. (Risk Management & Lifecycle; RSK-Q1; controls GL-01, GL-02, GL-03)
- Extend threat modelling, security review and vulnerability management to all AI systems and model supply chains. (Security & Resilience; SEC-Q1; controls IS-01, IS-10)
- Approve and publish an AI governance policy with a named executive owner and accountability model. (Strategy & Accountability; STR-Q1; controls AO-01, AO-03)

- Charter a cross-functional AI governance forum with documented authority to approve, restrict or stop use cases. (Strategy & Accountability; STR-Q2; controls AO-02)
- Document data sources, classifications and data flows for each material AI system. (Data & Privacy; DAT-Q1; controls EI-06, IS-02)

Days 61–90 — scale and automate

- No actions in this horizon based on your answers.

7. Recommended VERITRAIL controls

Control	Pillar	Priority	NIST AI RMF	ISO/IEC 42001	EU AI Act
EI-01 Enterprise AI inventory (system of record)	EI	critical	GOVERN 1.6	A.4.2, 7.5	Art. 26, Art. 49
EI-09 Shadow AI discovery	EI	medium	GOVERN 1.6	A.4.2	—
IS-04 Sensitive data redaction and masking	IS	critical	MEASURE 2.10	A.7.4, A.6.2.6	Art. 10
IS-03 Privacy assessment and data minimisation	IS	critical	MEASURE 2.10, MAP 1.1	A.7.4, A.5.4	Art. 10
IS-14 Prompt-injection and data-leakage testing	IS	critical	MEASURE 2.7	A.6.2.4	Art. 15
IS-11 Least-privilege tool access	IS	critical	MEASURE 2.7, MANAGE 2.2	A.6.2.6, A.4.4	Art. 15, Art. 14
IS-12 Runtime guardrails and policy enforcement	IS	high	MANAGE 2.2, MANAGE 2.4, MEASURE 2.7	A.6.2.6	Art. 15, Art. 14
IS-15 Kill switch and rollback	IS	critical	MANAGE 2.4	A.6.2.6	Art. 14
SE-05 Audit-ready evidence packs	SE	high	GOVERN 1.4, MEASURE 2.9	7.5, 9.2	Art. 11, Art. 18
SE-08 Immutable action logging	SE	critical	MEASURE 2.8, MANAGE 4.1	A.6.2.8	Art. 12, Art. 19, Art. 26

Framework mappings are indicative VERITRAIL interpretations (Control Library v1.0.0).

8. Framework readiness indicators (indicative — not a compliance determination)

NIST AI RMF

Area	Indicator	Band	Based on questions
GOVERN	52.0	Partial readiness	STR-Q1, STR-Q2, STR-Q3, HUM-Q3, ASR-Q3
MAP	48.0	Limited readiness	INV-Q1, INV-Q2, INV-Q3, RSK-Q1, DAT-Q1
MEASURE	52.0	Partial readiness	SEC-Q2, FST-Q1, HUM-Q2, ASR-Q1, DAT-Q2
MANAGE	44.0	Limited readiness	RSK-Q2, RSK-Q3, SEC-Q3, HUM-Q1, ASR-Q2

ISO/IEC 42001

Area	Indicator	Band	Based on questions
Context & leadership (Cl. 4–5, A.2–A.3)	53.3	Partial readiness	STR-Q1, STR-Q2, STR-Q3
Planning & impact assessment (Cl. 6, A.5)	53.3	Partial readiness	INV-Q2, RSK-Q1, FST-Q1
Support & documented information (Cl. 7, A.4)	40.0	Limited readiness	HUM-Q3, INV-Q1, ASR-Q2
Operation & lifecycle (Cl. 8, A.6–A.7)	55.0	Partial readiness	RSK-Q2, DAT-Q1, DAT-Q2, SEC-Q1
Performance evaluation (Cl. 9)	50.0	Partial readiness	HUM-Q2, ASR-Q1
Improvement (Cl. 10)	50.0	Partial readiness	ASR-Q3, RSK-Q3

EU AI Act

Area	Indicator	Band	Based on questions
AI literacy (Art. 4)	40.0	Limited readiness	HUM-Q3
Risk management (Art. 9)	46.7	Limited readiness	RSK-Q1, RSK-Q2, INV-Q2
Data governance (Art. 10)	60.0	Partial readiness	DAT-Q1, DAT-Q2, FST-Q1
Technical documentation & record-keeping (Art. 11–12)	40.0	Limited readiness	INV-Q3, ASR-Q2
Transparency (Art. 13, Art. 50)	40.0	Limited readiness	FST-Q2, FST-Q3
Human oversight (Art. 14)	50.0	Partial readiness	HUM-Q1, SEC-Q3
Accuracy, robustness & cybersecurity (Art. 15)	50.0	Partial readiness	SEC-Q1, SEC-Q2
Post-market monitoring & incidents (Art. 72–73)	50.0	Partial readiness	HUM-Q2, ASR-Q1

These indicators summarise self-reported practices that relate to each framework area. They do not indicate conformity with ISO/IEC 42001, compliance with the EU AI Act, or alignment with NIST AI RMF, and EU AI Act applicability depends on your role (provider/deployer) and system classification.

9. Recommended VERITRAIL modules

- **VERITRAIL Assess** — Establish an evidence-based baseline of maturity and use-case risk.
- **VERITRAIL Register** — Create a single, owned and classified AI system of record.
- **VERITRAIL Control** — Operationalise policies, approval gates and lifecycle workflows.
- **VERITRAIL Shield** — Enforce runtime guardrails, approvals and containment for LLM apps and agents.
- **VERITRAIL Assurance** — Test controls continuously and produce audit-ready evidence packs.
- **VERITRAIL Agent** — Accelerate assessments, gap analysis and reporting with a citation-backed governance copilot.

10. Next step: VERITRAIL Governance Baseline

A fixed-scope 4–6 week engagement — inventory up to 25 AI systems, validate this maturity baseline with evidence, deep-dive five priority systems, review two agents, and deliver a gap register, remediation roadmap and executive readiness report.

Book an VERITRAIL Governance Baseline: /contact/book-governance-baseline/

Appendix A — Your answers

Question	Answer
STR-Q1: Does your organization have a documented AI governance policy and accountable ownership model?	3 — Defined for some systems
STR-Q2: Is there a cross-functional AI governance forum with authority to approve, restrict, or stop AI use cases?	3 — Defined for some systems
STR-Q3: Are AI roles, responsibilities, and escalation paths defined for business, technology, risk, legal, and security teams?	2 — Initial / ad hoc
INV-Q1: Does your organization maintain a complete inventory of AI systems, models, agents, and vendor AI products?	2 — Initial / ad hoc
INV-Q2: Are AI systems classified by business criticality, data sensitivity, decision impact, autonomy, and regulatory relevance?	2 — Initial / ad hoc
INV-Q3: Can you identify the owner, purpose, users, data sources, and dependencies for each material AI system?	2 — Initial / ad hoc
RSK-Q1: Do AI use cases undergo risk assessment before production deployment?	3 — Defined for some systems
RSK-Q2: Are model, prompt, data, vendor, and agent changes subject to change control and reassessment?	2 — Initial / ad hoc
RSK-Q3: Is there a defined process for retiring, restricting, or remediating AI systems that no longer meet requirements?	2 — Initial / ad hoc
DAT-Q1: Are data sources, data classifications, and data flows documented for AI systems?	3 — Defined for some systems

Question	Answer
DAT-Q2: Are privacy, consent, retention, cross-border transfer, and data-minimization requirements assessed?	3 — Defined for some systems
DAT-Q3: Are sensitive data fields redacted, masked, or excluded from prompts, logs, and external model calls?	2 — Initial / ad hoc
SEC-Q1: Are AI systems included in threat modeling, security review, and vulnerability-management processes?	3 — Defined for some systems
SEC-Q2: Are LLM applications and agents tested for prompt injection, jailbreak, data leakage, and unsafe tool use?	2 — Initial / ad hoc
SEC-Q3: Can you disable or roll back an AI system, model, agent, or tool quickly after a security or safety incident?	2 — Initial / ad hoc
FST-Q1: Are AI systems assessed for bias, discriminatory outcomes, safety risks, and unintended harm?	3 — Defined for some systems
FST-Q2: Are users informed when they are interacting with AI or when AI materially influences a decision?	2 — Initial / ad hoc
FST-Q3: Are explanations, disclosures, and appeal mechanisms available for affected individuals where appropriate?	2 — Initial / ad hoc
HUM-Q1: Are human-review, override, escalation, and appeal mechanisms defined for high-impact AI decisions?	3 — Defined for some systems
HUM-Q2: Are AI systems monitored for performance, drift, misuse, incidents, and unexpected behavior?	3 — Defined for some systems
HUM-Q3: Are operators and affected teams trained on AI limitations, escalation paths, and responsible use?	2 — Initial / ad hoc
ASR-Q1: Are AI controls tested periodically, with evidence retained for audit and review?	2 — Initial / ad hoc
ASR-Q2: Can your organization produce an audit-ready evidence pack for a material AI system on request?	2 — Initial / ad hoc
ASR-Q3: Are AI governance metrics reviewed by leadership and used to drive corrective action?	3 — Defined for some systems

Appendix B — Sources

- VERITRAIL Control EI-01: Enterprise AI inventory (system of record) (Control Library v1.0.0)
- VERITRAIL Control EI-09: Shadow AI discovery (Control Library v1.0.0)
- VERITRAIL Control IS-04: Sensitive data redaction and masking (Control Library v1.0.0)
- VERITRAIL Control IS-03: Privacy assessment and data minimisation (Control Library v1.0.0)
- VERITRAIL Control IS-14: Prompt-injection and data-leakage testing (Control Library v1.0.0)
- VERITRAIL Control IS-11: Least-privilege tool access (Control Library v1.0.0)
- VERITRAIL Control IS-12: Runtime guardrails and policy enforcement (Control Library v1.0.0)
- VERITRAIL Control IS-15: Kill switch and rollback (Control Library v1.0.0)
- VERITRAIL Control SE-05: Audit-ready evidence packs (Control Library v1.0.0)
- VERITRAIL Control SE-08: Immutable action logging (Control Library v1.0.0)
- VERITRAIL Control IS-08: Transparency and AI disclosures (Control Library v1.0.0)
- VERITRAIL Self-Assessment template VERITRAIL-SA-MATURITY v1.0.0

VERITRAIL supports governance readiness, control implementation and evidence collection. It does not certify ISO/IEC 42001 conformity, guarantee EU AI Act compliance, or replace legal advice. Framework mappings are indicative.